SK Shieldus Rookies

상세 진단 보고서 (실무진용)

모의 교육 플랫폼 취약점 진단 결과

러닝브릿지(가상) 온라인 교육 플랫폼

문서 번호	SCAN-2026-003-T	**진단 일자**	2026-10-02
진단 대상	웹 서비스 (localhost:5000)	**작성일**	2026-10-07
작성	SK쉴더스 루키즈 34기 1석삼조 팀	**대상 독자**	정보보호·개발·운영 담당자

본 보고서는 SK쉴더스 루키즈 교육과정의 프로젝트 산출물이며, SK쉴더스의 공식 진단 보고서가 아닙니다.

1. 진단 개요

1.1 대상 및 범위

자산	자산 ID	개인정보 처리	점검 항목
웹 서비스 (localhost:5000)	LOCALHOST-5000	처리	3개

1.2 적용 기준

구분	문서	버전	시행일
법률	개인정보 보호법	법률 제21445호	2026-09-11
고시	개인정보의 안전성 확보조치 기준	개인정보보호위원회고시 제2026-9호	2026-07-01
인증기준	ISMS-P 인증기준 안내서	2023.11	-

1.3 법령·인증기준 매핑 방식

취약점과 법령·ISMS-P 인증기준의 매핑은 llm+rule으로 수행했습니다 (모델 gpt-4.1-mini, 프롬프트 v3/n2). 담당자 검토를 마친 매핑은 `검토 완료`, 아직 확인하지 않은 매핑은 `검토 전`으로 표시합니다. 현재 검토 전 매핑은 6건입니다.

2. 진단 결과 요약

점검 3개 항목 중 취약 2개, 양호 1개입니다. 전체 위험 수준은 **심각**(개인정보를 처리하는 자산에 '상' 위험 취약점이 있음)으로 판정했습니다.

2.1 위험도별 현황

위험도	취약 항목
상	1개
중	1개
하	0개

2.2 항목별 결과

항목	점검 항목	대상 자산	위험도	결과
IL-COMMENT-01	주석 내 정보 누출	웹 서비스 (localhost:5000)	상	취약
IL-ERRORPAGE-01	에러페이지 정보 노출	웹 서비스 (localhost:5000)	중	취약
IL-MASKING-01	중요 정보 마스킹 미흡	웹 서비스 (localhost:5000)	하	양호

3. 취약점 상세

3.1 주석 내 정보 누출 (IL-COMMENT-01) 상

식별 번호	SCAN-2026-003-IL-COMMENT-01-LOCALHOST-5000
대상 자산	웹 서비스 (localhost:5000) (LOCALHOST-5000), 개인정보 처리
설명	로그인 페이지의 HTML 주석에 테스트 계정의 아이디와 비밀번호가 노출되어 있습니다. 이는 계정 정보가 외부에 쉽게 노출될 수 있는 원인입니다.
영향	공격자가 이 정보를 이용해 시스템에 무단 접근할 수 있으며, 개인정보 유출 및 서비스 신뢰도 하락의 위험이 있습니다.
현황	http://localhost:5000/login 경로에서 주석 내 정보 누출 확인. 로그인 페이지 HTML 주석에 실제 로그인 가능한 테스트 계정의 아이디와 비밀번호가 남아 있어 누구나 열람할 수 있음 확인된 정보: <!-- 테스트 계정: student1 / student123 -->
판단 기준	양호: 중요 정보가 마스킹 처리되어 있으며, 서비스 운영 및 서버 사이드의 구조를 파악할 수 있는 불필요한 정보가 노출되지 않는 경우 / 취약: 중요 정보가 평문으로 노출되거나, 서비스 운영 및 서버 사이드의 구조를 파악할 수 있는 과도한 정보가 노출되는 경우
조치 방법	중요 정보를 마스킹 처리하고, 샘플 페이지나 불필요한 정보를 제공하는 요소를 삭제하여 과도한 정보 노출을 최소화함으로써 민감 정보와 내부 시스템 구조의 노출을 방지함

관련 법령	**개인정보 보호법 제29조(안전조치의무)** 검토 전 제29조(안전조치의무) 개인정보처리자는 개인정보가 유출등이 되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적 · 관리적 및 물리적 조치를 하여야 한다. 매핑 근거: 로그인 페이지 주석에 테스트 계정 정보가 노출되어 개인정보 유출 위험이 있으므로 개인정보 보호법 제29조의 안전성 확보 조치 의무에 위배된다. (근거: ISMS-P 2.5.1(사용자 계정 관리), 2.6.3(응용프로그램 접근) 관련 법규) **개인정보의 안전성 확보조치 기준 제5조 제4항, 제5항(접근 권한의 관리)** 검토 전 제5조(접근 권한의 관리) ① 개인정보처리자는 개인정보처리시스템에 대한 접근 권한을 업무 수행에 필요한 최소한의 범위로 차등 부여하여야 한다. ② 개인정보처리자는 개인정보취급자 또는 개인정보취급자의 업무가 변경되었을 경우 지체 없이 개인정보처리시스템의 접근 권한을 변경 또는 말소하여야 한다. ③ 개인정보처리자는 제1항 및 제2항에 의한 권한 부여, 변경 또는 말소에 대한 내역을 기록하고, 그 기록을 최소 3년간 보관하여야 한다. ④ 개인정보처리자는 개인정보처리시스템에 접근할 수 있는 계정을 발급하는 경우 정당한 사유가 없는 한 개인정보취급자 별로 계정을 발급하고 다른 개인정보취급자와 공유되지 않도록 하여야 한다. ⑤ 개인정보처리자는 개인정보취급자 또는 정보주체의 인증수단을 안전하게 적용하고 관리하여야 한다. ⑥ 개인정보처리자는 정당한 권한을 가진 자만이 개인정보처리시스템에 접근할 수 있도록 일정 횟수 이상 인증에 실패한 경우 개인정보처리시스템에 대한 접근을 제한하는 등 필요한 조치를 하여야 한다. 매핑 근거: 테스트 계정 아이디와 비밀번호가 주석에 노출되어 계정 공유 및 인증수단 관리가 미흡하므로 제4항(계정 공유 금지)과 제5항(인증수단 안전 관리)에 위배된다. (근거: ISMS-P 2.5.1(사용자 계정 관리), 2.6.3(응용프로그램 접근) 관련 법규) **개인정보의 안전성 확보조치 기준 제6조 제3항(접근통제)** 검토 전 ③ 개인정보처리자는 처리하는 개인정보가 인터넷 홈페이지, P2P, 공유설정 등을 통하여 권한이 없는 자에게 공개되거나 유출되지 않도록 개인정보처리시스템, 개인정보취급자의 컴퓨터 및 모바일 기기 등에 조치를 하여야 한다. 매핑 근거: 개인정보가 인터넷 홈페이지의 주석에 노출되어 권한 없는 자에게 공개되었으므로 제3항(권한 없는 자에게 개인정보 공개 금지)에 위배된다. (근거: ISMS-P 2.6.3(응용프로그램 접근) 관련 법규)
ISMS-P	**2.5.1 사용자 계정 관리** 검토 전 매핑 근거: 로그인 페이지 HTML 주석에 실제 로그인 가능한 테스트 계정의 아이디와 비밀번호가 노출되어 사용자 계정 및 접근권한 관리 절차가 미흡함을 보여준다. **2.6.3 응용프로그램 접근** 검토 전 매핑 근거: 응용프로그램 내에 테스트 계정 정보가 주석으로 노출되어 중요정보 노출 최소화 기준을 충족하지 못함을 나타낸다.
매핑 검토 메모	LLM 항 판단으로 제외한 조문: SAFE-12 제12조(출력 · 복사시 안전조치): 진단 근거는 출력 또는 복사시 안전조치에 관한 내용이 아니므로 해당하지 않는다.

3.2 에러페이지 정보 노출 (IL-ERRORPAGE-01) 중

식별 번호	SCAN-2026-003-IL-ERRORPAGE-01-LOCALHOST-5000
대상 자산	웹 서비스 (localhost:5000) (LOCALHOST-5000), 개인정보 처리

설명	에러페이지에서 스택 트레이스와 서버 내부 경로, DB 종류가 노출되어 있습니다. 이는 서버의 내부 구조가 외부에 노출되는 원인입니다.
영향	공격자가 서버 정보를 악용하여 추가적인 공격을 시도할 수 있으며, 이는 서비스 중단 및 데이터 유출로 이어질 수 있습니다.
현황	http://localhost:5000/student/grades?id=999 경로에서 에러페이지 정보 노출 확인. 존재하지 않는 id 요청 시 스택 트레이스와 서버 내부 경로, DB 종류가 응답에 그대로 노출됨 확인된 정보: Traceback (most recent call last): File "/app/routes.py", line 88; sqlite3.OperationalError: no such column
판단 기준	양호: 중요 정보가 마스킹 처리되어 있으며, 서비스 운영 및 서버 사이드의 구조를 파악할 수 있는 불필요한 정보가 노출되지 않는 경우 / 취약: 중요 정보가 평문으로 노출되거나, 서비스 운영 및 서버 사이드의 구조를 파악할 수 있는 과도한 정보가 노출되는 경우
조치 방법	중요 정보를 마스킹 처리하고, 샘플 페이지나 불필요한 정보를 제공하는 요소를 삭제하여 과도한 정보 노출을 최소화함으로써 민감 정보와 내부 시스템 구조의 노출을 방지함
관련 법령	매핑된 법령 없음
ISMS-P	**2.10.3 공개서버 보안** 검토 전 매핑 근거: 에러페이지에 스택 트레이스, 서버 내부 경로, DB 종류 등 민감한 정보가 노출되어 있어 공개서버 보안 기준의 접근통제 및 정보 노출 방지 요구를 미충족함.
매핑 검토 메모	선택된 기준에 [관련 법규]가 없어 조문을 비움 (팀 합의: LLM으로 채우지 않음)

4. 부록

4.1 기준 문서 원본

ID	원본 파일
PIPA-21445	개인정보 보호법(법률)(제21445호)(20260911).txt
SAFE-2026-9	개인정보의 안전성 확보조치 기준(고시)(제2026-9호)(20260701).txt
ISMSP-2023.11	ISMS-P 인증기준 안내서(2023.11).txt

4.2 보고서 생성 방식

결과 판정(위험도, 취약·양호, 전체 위험 수준)은 진단 데이터와 정해진 규칙으로 산출했습니다. 설명과 영향 문장은 AI가 작성했으며, 판단 기준과 조치 방법은 항목 카탈로그에서, 법령 조문은 기준 문서 원문에서 그대로 가져왔습니다.

유사 사례는 개인정보보호위원회 처분 보도자료 원문으로 확인한 사례 카드에서 검색했고, 과징금 노출액과 조치 우선순위는 아래 기준으로 코드가 계산했습니다. 금액은 AI를 거치지 않았습니다.

4.3 과징금 노출 산정

항목	값	근거·설명
법정 상한	1억 5,000만 원	전체 매출액에서 위반과 무관한 매출을 뺀 금액의 3%. 개인정보 보호법 제64조의2(과징금의 부과), 2026-09-11 시행 개정법
10% 특례 시나리오	5억 원	고의·중과실로 3년 내 같은 유형 반복 위반: 해당 없음 (고객사 프로필의 3년 내 위반 이력 기준. 고의·중과실 여부는 도구가 판단하지 않음) 고의·중과실로 피해 1천만 명 이상: 해당 없음 (정보주체 120,000명 → 1천만 명 기준 미달) 시정명령 불이행으로 유출: 해당 없음 (고객사 프로필의 시정명령 미이행 여부 기준)
투자 감경	최대 40%	보호 투자·보호체계 운영·추가 안전조치를 고려해 기준금액의 최대 40% 감경. 위반 전 3개 사업연도 노력을 보며 고의·중과실 위반은 제외. 상한 기준 예시 9,000만 원
ISMS-P 인증 감경	최대 30%	현재 미인증. ISMS-P 인증에 따른 감경 상한은 최대 30%(개정 전 50%). 중요 개인정보처리자 대상 인증 의무화는 2027-07-01 시행 예정

항목	값	근거·설명
유사 처분 사례 과징금	6건	최소 329만 원, 중앙값 20억 3,550만 원, 최대 151억 4,196만 원. 참고 사례를 뺀 등급(동일 결함·같은 유형·관련 통제)의 처분 사례 중 과징금이 있는 것만 집계. 사례 기업과 고객사의 매출 규모가 달라 예상 부과액이 아니라 '유사 사례에서 실제로 나온 금액'임 유사 사례 중앙값이 이 고객사의 법정 상한보다 큼. 사례 기업이 더 커서 생긴 차이이므로 사례 금액을 고객사 예상 과징금처럼 쓰면 안 됨 (상한을 넘는 과징금은 불가능)

4.4 조치 우선순위

순위	점검 항목	위험도	사례 근거	점수	여기까지 조치 시
1	주석 내 정보 누출	상	동일 결함	4.5	리스크 60.0% 감소
2	에러페이지 정보 노출	중	동일 결함	3.0	리스크 100.0% 감소

점수 = 심각도(상3·중2·하1) × 개인정보 자산(예 1.0·아니오 0.3) × (1 + 0.5 × 사례 근거(동일 결함 1.0·같은 유형 0.7·관련 통제 0.5·참고 0.3·없음 0.2)). 점수는 조치 순서를 정하기 위한 상대값이며 금액이 아닙니다.

4.5 산정 가정과 제외 항목

- 고객사 프로필(매출·정보주체 수 등)은 모의 교육 플랫폼 가정값
- 법정 상한은 최대치이며 예상 부과액이 아님
- 같은 조항에 걸린 취약점이 여러 개여도 법정 상한은 한 번만 적용
- 유사 사례 금액은 대부분 개정법 시행(2026-09-11) 이전 구법 기준 처분
- 투자 감경 예시값은 법정 상한에 최대 감경률을 적용한 것으로, 실제 감경은 기준금액에 적용됨
- 우선순위 점수는 조치 순서를 정하기 위한 상대 점수이며 금액이 아님

제외 항목	사유
중요 정보 마스킹 미흡	상태가 '양호'라 노출액 계산에서 제외
에러페이지 정보 노출	관련 법 조항이 없어 법적 노출액에서 제외 (ISMS-P 심사 리스크로만 다룸)